PDPL — Inactive User Handling Policy

Status: Requires Client/Legal Action **Owner:** Amna (or delegated data-protection officer) **Referenced by:** `pdpl-controls-matrix.csv` row PDPL-15

Why this needs client input

PDPL Article 18 (Storage Limitation) requires personal data to be kept no longer than is necessary for the purposes it was collected for. What counts as "no longer necessary" is a **business + legal decision**, not a technical one, because it depends on:

- What relationship (if any) the user has after they stop logging in
- What data must be retained for regulatory reasons (NELC/CME certificate holders → multi-year retention regardless of activity)
- Whether the user paid for anything (finance retention rules)
- What the Privacy Notice promised users at signup

Once the policy is decided, implementation in the existing `RetentionService` (`backends/src/modules/pdpl/retention.service.ts`) is ~2 hours of code.

Decisions the client must make

1. Inactivity threshold

How long since last login before an account is considered inactive?

- ☐ 12 months
- ☐ 18 months
- ☐ 24 months
- ☐ Other: _____

Recommendation: 18 months — covers a typical CME renewal cycle plus a buffer, so a user who returns to renew their certification does not find their account already anonymised.

2. Action on inactivity

What should happen when a user crosses the threshold?

- ☐ **Notify first, delete after grace** — email at threshold, hard-delete 30 days later if no login
- ☐ **Anonymise only** — retain enrollment/certificate history but scrub email + name (email replaced with `deleted-{uuid}@physioguidance.local`)
- ☐ **Soft-disable** — set isActive=false, keep row indefinitely, admin can manually re-enable
- ☐ **Do nothing** — retention is covered by other mechanisms

Recommendation: Notify first, delete after grace — for users with **no paid history and no active certificate**. Anonymise only — for users **with certificates issued** (regulator may audit certificates for years).

3. Exceptions

Which classes of users are **exempt** from inactive-user handling?

- ☐ Users with active paid enrollments (payment record within retention window)
- ☐ Users with issued CME certificates (multi-year regulator retention)
- ☐ Users with pending refund requests
- ☐ Users flagged as blocked/banned (kept for security)
- ☐ Instructors / admins (kept while role assignment is active)

Recommendation: All of the above. Deletion should only affect **student-role users with no paid enrollments, no issued certificates, no active refund case, and no blocked flag.**

4. Communication

- ☐ Email 30 days before deletion with re-login link
- ☐ Email 7 days before final deletion (reminder)
- ☐ No email (silent deletion)

Recommendation: Both emails. Sudden silent deletion generates support tickets and reputational risk.

What the implementation will look like once decided

Pseudocode of the addition to `RetentionService`:

```
// Runs nightly with the existing 02:00 UTC purge cron.
async purgeInactiveUsers() {
  const cutoff = subDays(new Date(), THRESHOLD_DAYS);
  const graceCutoff = subDays(new Date(), THRESHOLD_DAYS + GRACE_DAYS);

  // Notify users crossing the threshold today (once per user; audit_log
  // idempotency guard prevents re-emailing).
  const toNotify = await db.select().from(users).where(
    and(
      lt(users.lastLoginAt, cutoff),
      isNull(users.inactiveNotifiedAt),
      // Exception clauses — parametrised from client policy above.
      not(exists(activePaidEnrollment)),
      not(exists(issuedCertificate)),
      not(exists(pendingRefund)),
      eq(users.activeRole, 'STUDENT'),
    ),
  );
  await sendInactiveWarningEmails(toNotify);

  // Delete users past the grace window (also passing exception clauses).
  const toDelete = await db.select().from(users).where(
    and(
      lt(users.lastLoginAt, graceCutoff),
      isNotNull(users.inactiveNotifiedAt),
      /* same exception clauses */
    ),
  );
  await hardDeleteUsers(toDelete);

  // Audit summary written to audit_logs with action = 'pdpl.inactive_purge'.
}
```

Sign-off

Once the four decisions above are checked, mail this file back to Ghulam and the implementation will land in the next backend deploy. The `pdpl-controls-matrix.csv` row PDPL-15 will be updated from `Requires Client/Legal Action` to `Implemented` at that time.